ФІНАЛЬНЕ ТЕХНІЧНЕ ЗАВДАННЯ ДЛЯ GOOGLE AI STUDIO

STORKCRYPTO: TELEGRAM STARS + TON CONNECT

Дата: 31.10.2026
Проєкт: StorkCrypto Telegram Mini App
Production: `https://storkcrypto.pages.dev/`
Платформа: Telegram Mini App, Cloudflare Pages/Functions, React, Zustand, Supabase, TON Connect
Роль агента: Senior Full-Stack Engineer + Security Engineer + Chief Design Developer

---

1. Головна мета

Перевести StorkCrypto на просту, зрозумілу та безпечну модель:

```
Plain Text
```

```
Telegram Stars (XTR) → єдиний спосіб оплати PRO-підписки
TON Connect → єдиний спосіб підключення TON-гаманця
```

Не використовувати MetaMask, біржі або GRAM як альтернативні кнопки для цієї системи.

Після виконання завдання користувач повинен розуміти:

```
Plain Text
```

```
PRO Subscription
[Pay with Telegram Stars]

Portfolio Wallet
[Connect TON Wallet]
```

Застосунок не можна оголосити готовим, поки платіж не пройде повний server-side flow.

---

2. Обов’язкові обмеження платіжної архітектури

2.1. Telegram Stars

PRO є цифровою послугою всередині Telegram. Оплату PRO реалізувати через Telegram Stars із валютою:

```
Plain Text
```

```
XTR
```

Не використовувати для Telegram PRO:

- GRAM;
- TON як заміну Stars;
- MetaMask;
- біржі;
- довільні криптогаманці;
- frontend-only payment confirmation;
- localStorage як доказ оплати.

Telegram Stars і TON — різні системи. TON Connect не є заміною Telegram Stars для цифрової PRO-підписки.

2.2. TON Connect

TON Connect використовувати окремо для:

- підключення TON Wallet;
- відображення wallet address;
- disconnect;
- дозволених TON blockchain-взаємодій.

Підключення гаманця не повинно активувати PRO.

---

3. Видалення зайвих способів оплати та гаманців

3.1. Видалити з UI

Повністю прибрати з production interface:

- MetaMask;
- кнопки бірж;
- біржові payment options;
- GRAM payment button;
- `Pay with TON` для PRO;
- дублікати Telegram Wallet;
- непрацюючі exchange selectors;
- demo/fake payment buttons;
- непідтверджені wallet buttons;
- меню з великою кількістю несумісних payment providers.

3.2. Залишити

У PRO modal залишити лише:

```
Plain Text

Pay with Telegram Stars
```

У Portfolio залишити лише:

```
Plain Text

Connect TON Wallet
```

У wallet picker дозволити лише TON Connect-compatible wallets, наприклад:

- Telegram Wallet, якщо він доступний через TON Connect;
- Tonkeeper;
- MyTonWallet;
- інші wallets, які офіційно підтримують TON Connect.

Назви та список повинні надходити від TON Connect UI, а не бути фіктивно намальовані у frontend.

---

4. Telegram Stars: обов’язковий повний flow

4.1. Створення invoice

Створити або виправити Cloudflare Function:

```
Plain Text

/functions/api/payments/stars/create.ts
```

Endpoint:

```
Plain Text

POST /api/payments/stars/create
Authorization: tma <Telegram.WebApp.initData>
Content-Type: application/json
```

Request:

```
JSON

{
  "plan": "pro_monthly"
}
```

Backend повинен:

1. Перевірити Telegram `initData` через HMAC.
2. Отримати справжній Telegram user id тільки з валідованого initData.
3. Не приймати `userId` з frontend як trusted value.
4. Не приймати amount з frontend.
5. Визначати plan і ціну на backend.
6. Використовувати currency `XTR`.
7. Створювати унікальний order id.
8. Створювати унікальний invoice payload.
9. Зберігати order у database зі статусом `PENDING`.
10. Повертати справжній Telegram invoice link.

Відповідь:

JSON

```
{
  "success": true,
  "invoiceUrl": "https://t.me/$...",
  "order": {
    "orderId": "...",
    "planId": "PRO",
    "currency": "XTR",
    "amount": 250,
    "status": "PENDING",
    "expiresAt": "..."
  }
}
```

4.2. Критичний security test

У production:

Plain Text

```
POST /api/payments/stars/create без initData → 401
POST із порожнім initData → 401
POST із fake-init-data → 401
POST із чужим user id → 401/403
```

Заборонити fallback:

Plain Text

```
userId: "tg_user"
```

`tg_user` не повинен існувати у production payment path.

4.3. Відкриття invoice у Telegram

У frontend використовувати:

Plain Text

```
const tg = window.Telegram?.WebApp;

if (!tg?.initData) {
  showError('Відкрийте StorkCrypto всередині Telegram');
  return;
```

```
}

const response = await fetch('/api/payments/stars/create', {
  method: 'POST',
  headers: {
    'Content-Type': 'application/json',
    'Authorization': `tma ${tg.initData}`,
  },
  body: JSON.stringify({ plan: 'pro_monthly' }),
});

const data = await response.json();

if (!response.ok || !data.invoiceUrl) {
  throw new Error(data.error || 'Invoice was not created');
}

tg.openInvoice(data.invoiceUrl, (status) => {
  // callback не є доказом successful payment
  refreshSubscriptionFromServer();
});
```

Якщо застосунок відкритий у звичайному браузері:

```
Plain Text

Оплата PRO доступна всередині Telegram.
[Відкрити в Telegram]
```

Не показувати success лише через redirect або callback.

---

5. Telegram webhook і server-side activation

Реалізувати backend webhook для Telegram Bot API.

5.1. pre_checkout_query

Backend повинен:

1. Знайти order через `invoice_payload`.
2. Перевірити Telegram user id.

3. Перевірити currency `XTR`.
4. Перевірити amount.
5. Перевірити plan.
6. Перевірити order status `PENDING`.
7. Відповісти на `pre_checkout_query` протягом 10 секунд.
8. Відхилити невідомий або змінений order.

5.2. successful_payment

PRO активувати тільки після отримання Telegram update:

```
Plain Text

message.successful_payment
```

Перевірити:

- `invoice_payload`;
- `currency === XTR`;
- `total_amount`;
- Telegram user id;
- `telegram_payment_charge_id`;
- order status;
- термін дії order;
- відповідність plan.

Зберегти payment server-side і в одній database transaction:

```
Plain Text

order → PAID
payment → CONFIRMED
subscription → ACTIVE
```

Створити unique constraint для:

```
Plain Text

telegram_payment_charge_id
```

Повторний webhook не повинен створювати другу підписку.

5.3. Заборонено активувати PRO після

- натискання Pay;
- створення invoice;
- відкриття invoice;
- закриття invoice;
- callback зі статусом `paid` без backend confirmation;
- підключення TON Wallet;
- зміни localStorage;
- зміни Zustand state без відповіді server.

---

6. Реальний subscription status API

Створити:

```
Plain Text

/functions/api/payments/stars/status.ts
```

Endpoint:

```
Plain Text

GET /api/payments/stars/status?orderId=...
Authorization: tma <Telegram.WebApp.initData>
```

Очікувана поведінка:

```
Plain Text

без auth → 401
чужий order → 403
невідомий order → 404
валідний pending order → JSON PENDING
оплачений order → JSON PAID + subscriptionActive true
```

Ніколи не повертати `index.html` для `/api/*`.

Приклад відповіді:

JSON

```
{
  "orderId": "...",
  "status": "PAID",
  "paymentVerified": true,
  "subscriptionActive": true,
  "plan": "PRO",
  "expiresAt": "2026-11-30T12:00:00.000Z"
}
```

Після закриття invoice frontend повинен опитувати цей endpoint. До `paymentVerified: true` показувати:

Plain Text

```
Перевірка платежу…
```

а не `PRO active`.

---

7. TON Connect Wallet

7.1. Один root provider

Підключити TON Connect один раз у root:

TSX

```
<TonConnectUIProvider
  manifestUrl="https://storkcrypto.pages.dev/tonconnect-manifest.json"
>
  <App />
</TonConnectUIProvider>
```

Не створювати provider у кожній вкладці, modal або render.

7.2. Manifest

Файл:

Plain Text

```
https://storkcrypto.pages.dev/tonconnect-manifest.json
```

Повинен повертати `HTTP 200`, JSON і public HTTPS icon.

Використати PNG:

JSON

```
{
  "url": "https://storkcrypto.pages.dev",
  "name": "StorkCrypto",
  "iconUrl": "https://storkcrypto.pages.dev/icon-180.png",
  "termsOfUseUrl": "https://storkcrypto.pages.dev/terms",
  "privacyPolicyUrl": "https://storkcrypto.pages.dev/privacy"
}
```

Перевірити:

Plain Text

```
GET /tonconnect-manifest.json → 200
GET /icon-180.png → 200
Content-Type: application/json
Content-Type: image/png
HTTPS
CORS доступний
```

7.3. Portfolio UI

Додати явний блок:

Plain Text

```
TON Wallet
Not connected
[Connect TON Wallet]
```

Після підключення:

Plain Text

```
TON Wallet
Connected
```

```
UQ12…ABCD
[Copy] [Explorer] [Disconnect]
```

Використовувати:

```tsx
useTonAddress()
useTonWallet()
useIsConnectionRestored()
```

Після `wallet !== null`:

- закрити picker;
- прибрати overlay;
- оновити статус;
- показати скорочену адресу;
- показати назву wallet application.

Після disconnect:

- очистити address;
- очистити wallet name;
- показати Connect TON Wallet;
- не залишати orphan modal.

7.4. Wallet security

Не вважати wallet address оплатою.

Не робити:

```
wallet connected → PRO active
```

Не зберігати private key, seed phrase або secret у frontend, localStorage чи Supabase.

---

8. Видалення fake/demo логіки

З production bundle та Cloudflare Functions видалити або ізолювати:

- `tg_user` fallback;
- fake payment success;
- fake wallet connected state;
- demo invoice success;
- hardcoded PRO flag;
- admin bypass y frontend;
- test secret;
- fake Gram payment;
- fake transaction hash.

Demo Simulator може залишатися лише як окремий віртуальний режим, але він не повинен виглядати як реальна оплата або реальне підключення гаманця.

---

9. Modal system

Правила:

- усі інформаційні та технічні modals — fullscreen;
- PRO subscription — єдиний компактний виняток;
- `position: fixed; inset: 0` ;
- z-index вище ticker і bottom navigation;
- `role="dialog"` ;
- `aria-modal="true"` ;
- Escape закриває modal;
- кнопка close завжди доступна;
- body scroll lock видаляється після close;
- після close overlay повністю видаляється з DOM;
- не повинно бути orphan overlays.

Перевірити 30 циклів для:

- asset detail;
- Neural Summary;
- Academy lesson;

- News detail;
- Portfolio;
- PRO modal;
- wallet picker;
- wallet status;
- error/retry;
- Analytical Companion.

Очікування після кожного циклу:

```
Plain Text
```

```
visible dialogs = 0
orphan overlays = 0
body scroll restored
bottom navigation clickable
```

---

10. Loading screen і дизайн

Працюй як **Chief Design Developer**.

10.1. Не руйнувати Manifesto

Зберегти:

- вертикальну композицію;
- темний branded background;
- приблизно 6,5 секунди;
- плавний transition до dashboard;
- серйозну crypto/blockchain атмосферу;
- не багатокольорову палітру.

Не використовувати:

- `GENESIS`;
- semicircle disappearance;
- стандартний spinner замість Manifesto;

- хаотичні rainbow colors;
- надто швидку або дитячу анімацію.

10.2. Бажана анімація

Послідовність:

```
Plain Text

rotating concentric rings
→ realistic dissipating fog
→ StorkCrypto text emerges
→ letters visibly fracture
→ letters dissolve into clear pixels
→ pixels fall down in controlled sequence
→ pixels converge horizontally as data
→ final geometric blockchain/coin motif
→ dashboard
```

Вимоги:

- pixel particles мають бути чітко видимими;
- рух має бути плавним і контрольованим;
- `StorkCrypto` трохи збільшити для читабельності;
- на 360×800 назва залишається в один рядок;
- не використовувати надто абстрактні або нудні ефекти;
- loading screen залишається темним і професійним.

10.3. Main interface

Після loading:

- smooth fade/transition;
- жодного blank flash;
- темна premium crypto-terminal естетика;
- не багатокольоровий dashboard;
- компактний яскравий `StorkCrypto`;
- мінімальне збільшення шрифтів для читабельності;
- яскравий accent, але не rainbow palette;

- відсутність horizontal overflow;
- коректна safe-area підтримка Telegram WebView.

---

11. Дані та статуси

Якщо API повертає cache:

```
Plain Text
STALE або DELAYED
```

Якщо є актуальний успішний response:

```
Plain Text
LIVE
```

Додати:

- last updated time;
- Retry;
- пояснення джерела;
- distinction між DEMO, CACHE, STALE, ERROR;
- відсутність суперечливих `STALE + LIVE`.

Не показувати `LIVE`, якщо дані походять із cache.

---

12. Academy localization

Перемикання UA/EN/RU повинно змінювати:

- заголовок;
- опис;
- рівень;
- tags;
- CTA;
- lesson title;

- video title;
- quiz;
- error/fallback text.

Зміна лише `aria-pressed` не вважається локалізацією.

Перевірити три мови на mobile viewport.

---

13. Cloudflare deployment

Після змін обов’язково:

1. Зробити commit.
2. Переконатися, що Cloudflare Pages build завершився без помилок.
3. Перевірити production deployment commit SHA.
4. Перевірити, що Cloudflare Functions реально опубліковані.
5. Secrets додати тільки у Cloudflare environment.
6. Не розміщувати bot token або Supabase service role у frontend.
7. Перевірити, що `/api/*` не повертає SPA `index.html`.
8. Очистити cache або використати новий deployment URL.
9. Перевірити саме `https://storkcrypto.pages.dev/`, а не localhost.
10. Перевірити production logs.

---

14. Обов’язкові acceptance tests

Telegram Stars

Plain Text

```
1. Mini App відкрито всередині Telegram.
2. initData присутній.
3. Без initData create → 401.
4. Fake initData → 401.
5. З валідним initData create → реальний XTR invoice.
6. Pay відкриває Telegram invoice одразу.
7. Cancel залишає BASIC.
```

```
8. pre_checkout_query підтверджується backend.
9. successful_payment отримується backend.
10. До successful_payment PRO неактивний.
11. Після successful_payment PRO active.
12. Reload зберігає subscription через backend.
13. Duplicate webhook не створює другу підписку.
14. Невідомий order не активує PRO.
```

Web

Plain Text

```
1. У браузері показується Open in Telegram.
2. Redirect не показує фальшивий success.
3. Order status polling повертає JSON.
4. Чужий order недоступний.
```

TON Wallet

Plain Text

```
1. Portfolio має Connect TON Wallet.
2. Picker відкривається.
3. User обирає TON wallet.
4. Picker закривається автоматично.
5. Показано Connected.
6. Показано shortened address.
7. Copy працює.
8. Explorer працює.
9. Disconnect працює.
10. Reload коректно відновлює session.
11. 30 connect/disconnect cycles не залишають overlay.
12. Wallet connect не активує PRO.
```

UI/UX

Plain Text

```
1. Loading 6,5 с ± 100 мс.
2. StorkCrypto поміщається в один рядок на 360×800.
3. Rings → fog → fracture → pixels → convergence → dashboard.
4. Немає semicircle disappearance.
```

```
5. Немає blank flash.
6. Day/Night працюють.
7. Academy UA/EN/RU реально змінюють контент.
8. Усі інформаційні modals fullscreen.
9. PRO modal — компактний виняток.
10. 30 modal cycles без orphan overlays.
```

Security

Plain Text

```
1. Production bundle не містить bot token.
2. Production bundle не містить Supabase service role.
3. Немає tg_user fallback.
4. Немає hardcoded admin credentials.
5. Немає fake payment success.
6. Немає private key/seed phrase storage.
7. API routes повертають правильні HTTP statuses.
8. Немає uncaught console errors.
```

---

15. Формат фінального звіту AI-агента

Plain Text

```
Змінені файли:
- ...

Cloudflare:
- production deployment SHA: ...
- Functions deployed: PASS/FAIL
- secrets configured: PASS/FAIL

Telegram Stars:
- initData validation: PASS/FAIL
- XTR invoice: PASS/FAIL
- invoice opens: PASS/FAIL
- pre_checkout_query: PASS/FAIL
- successful_payment: PASS/FAIL
- server-side PRO activation: PASS/FAIL
- duplicate protection: PASS/FAIL

TON Connect:
- manifest: PASS/FAIL
```

```
- PNG icon: PASS/FAIL
- Connect button: PASS/FAIL
- picker closes: PASS/FAIL
- address visible: PASS/FAIL
- disconnect: PASS/FAIL

UI/UX:
- loading timing: PASS/FAIL
- loading animation: PASS/FAIL
- themes: PASS/FAIL
- localization: PASS/FAIL
- modal 30-cycle: PASS/FAIL

Security:
- secrets scan: PASS/FAIL
- auth bypass test: PASS/FAIL
- fake payment test: PASS/FAIL

Залишкові ризики:
- ...

Фінальний статус:
READY / NOT READY
```

Статус `READY` заборонено встановлювати, якщо:

- Stars invoice не відкривається;
- create endpoint приймає запит без initData;
- status endpoint повертає HTML;
- PRO активується без successful_payment;
- TON picker не закривається;
- wallet address не відображається;
- Cloudflare deployment не підтверджений;
- modal stress test має orphan overlay.

Офіційні посилання

- Telegram Stars: https://core.telegram.org/bots/payments-stars
- Telegram Mini Apps: https://core.telegram.org/bots/webapps

- Telegram Blockchain Guidelines: https://core.telegram.org/bots/blockchain-guidelines
- TON Connect overview: https://docs.ton.org/applications/ton-connect/overview
- TON Connect get started: https://docs.ton.org/applications/ton-connect/get-started